

Care Access Navigator

Risk Management Rubric - Criterion 6: Risk Management Implementation

Purpose

This criterion focuses on putting the risk-management process into operation. It brings together the earlier work on risk identification, evaluation, mitigation, and communication and turns it into a complete implementation program with realistic timing, assigned resources, framework alignment, customization, historical tracking, and continuous monitoring.

1. Build the Risk Management Program Plan

- What:** Creating one practical implementation plan that connects the Care Access Navigator risk register, selected controls, owners, evidence, monitoring, and reporting activities.
- How:** Using the existing Identity and Access Management (IAM), Governance, Risk, and Compliance (GRC), Security Information and Event Management (SIEM), access-review, remediation, and reporting workstreams and organizing them into a phased program.
- Why:** The rubric requires more than individual risk documents. A program plan is showing how the different risk-management activities are being carried out together over time.

Program Element	Care Access Navigator Implementation
Risk Register	Maintaining risks, owners, inherent scores, treatment decisions, residual risk, status, and evidence references.
Control Matrix	Linking IAM, authentication, access-review, monitoring, incident, and remediation controls to identified risks.
Evidence Index	Tracking screenshots, logs, approvals, access reviews, test results, and remediation evidence.
Exceptions / Remediation	Recording gaps, failed tests, corrective actions, owners, target dates, and closure evidence.
Management Reporting	Using Tableau / summary reporting to communicate risk posture, control status, incidents, and remediation.

2. Use a Phase-Based Deployment Strategy

- What:** Implementing the risk-management program in phases instead of attempting all controls and monitoring activities at once.
- How:** Sequencing foundation work, control implementation, testing, remediation, continuous monitoring, and reporting so each phase is producing evidence for the next phase.
- Why:** A phase-based approach is making the implementation realistic for the 12-week project and is reducing the risk of incomplete or disconnected deliverables.

Phase	Main Activities	Primary Output
Phase 1 - Foundation	Confirm scope, risk methodology, roles, assets, tools, register structure, control inventory	Approved risk-management foundation
Phase 2 - Control Implementation	Configure/test RBAC, JML, authentication, MFA, privileged/vendor access, logging	Implemented IAM/security controls
Phase 3 - Assessment and Testing	Perform access reviews, control tests, alert tests, incident simulation, gap assessment	Test results, exceptions, evidence
Phase 4 - Remediation	Assign corrective actions, update treatments, close or accept exceptions	Remediation log and updated residual risk
Phase 5 - Monitoring and Reporting	Track indicators, thresholds, environmental changes, risk history, dashboard metrics	Ongoing monitoring and management reporting

3. Define the Implementation Timeline and Resource Allocation

- What:** Assigning realistic timing, owners, and tools/resources to the major implementation activities.
- How:** Using existing project roles such as IAM Analyst, Security Analyst, GRC Analyst, Department Manager, and HR/Workforce Administrator and aligning activities to the available lab tools and project schedule.

Why: A risk-management program cannot be implemented without ownership and resources. This step is showing who is doing the work and what they are using.

Activity	Owner	Timing	Resources
Maintain risk register and evidence index	GRC Analyst	Ongoing	Excel/Word, Monday.com, evidence files
Validate RBAC and least privilege	IAM Analyst	1 week / review as needed	Keycloak, RBAC matrix, access tests
Test Joiner-Mover-Leaver lifecycle	IAM Analyst + HR role	1 week / event-based retest	Keycloak, JML workflow, screenshots
Validate MFA and privileged-access controls	IAM + Security Analyst	1 week / after changes	Keycloak settings, test cases
Run SIEM detection and alert-triage tests	Security Analyst	1-2 weeks / recurring tests	Sentinel or equivalent simulation
Perform access review and remediation	GRC + Department Manager	Quarterly simulation / project cycle	Review workbook, approvals, remediation tracker
Update Tableau / management reporting	GRC Analyst	Monthly / final reporting	Tableau, Excel/CSV metrics

4. Implement the Chosen Framework With Customization

What: Using National Institute of Standards and Technology (NIST) risk-management and cybersecurity framework concepts as the primary structure, with supporting ISO/IEC 27001 concepts where useful.

How: Customizing the framework to the simulated healthcare environment, synthetic data, seven representative roles, Keycloak, lightweight applications, monitoring simulations, and practical evidence artifacts.

Why: The rubric requires documented customization and gap analysis. The project is demonstrating how a recognized framework is being applied proportionately without claiming enterprise certification.

Framework Activity	Project Customization
Categorize / Identify	Using synthetic ePHI, workforce identities, Keycloak, EHR Simulator, Patient Portal, Billing App, HR App, logs, and GRC records as scoped assets.
Select / Protect	Using RBAC, least privilege, JML, MFA, privileged/vendor controls, and access-review controls.
Assess / Detect	Using controlled access tests, log review, SIEM-style detections, access reviews, and control tests.
Authorize / Govern	Using defined risk owners, manager/GRC review, treatment decisions, and residual-risk acceptance concepts.
Monitor	Using risk history, KPI tracking, alerts, access-review results, remediation status, and environmental-change checks.

5. Document the Gap Analysis and Integration Procedures

What: Identifying where expected controls are not fully implemented and documenting how each gap is being handled.

How: Comparing expected controls with the actual project state, recording gaps as Not Started, Partial, In Progress, or Done, and linking each gap to an owner, remediation action, evidence, and related risk.

Why: Gap analysis is showing the difference between the intended control environment and the actual implemented environment, while integration procedures show how IAM, monitoring, access review, remediation, and reporting work together.

Area	Starter Gap / Status	Integration / Corrective Action
MFA coverage	Partial	Confirm privileged/admin coverage, configure/test, attach evidence, update related risk.
Leaver deprovisioning	Not Yet Tested	Run a leaver scenario, verify disablement, log exception if unsuccessful.
Privileged access review	Partial	Validate privileged membership and monitoring, record remediation.
Periodic access review	Not Yet Tested	Complete review, document stale/excessive access and corrective actions.
SIEM detection use cases	Not yet Tested	Test failed-login, privilege-escalation, and expired-account scenarios and tune alerts.

Area	Starter Gap / Status	Integration / Corrective Action
Dashboard data integration	Not yet Tested	Link risk, control, access-review, incident, and remediation metrics into Tableau / summary reporting.

6. Create Historical Tracking in the Risk Register

What:	Keeping earlier risk scores and control states instead of overwriting them when the project changes.
How:	Recording a new review entry whenever a control is implemented, a test is completed, a risk score changes, or remediation is closed, with the date, reason, and evidence.
Why:	Historical tracking is showing whether risk is improving, worsening, or remaining unchanged over time.

Date	Risk	Status / Score	Change	Evidence / Reason
09/18/2026	R02 Terminated account remains active	Inherent 15 - Critical	Initial assessment	Leaver workflow defined; test pending
TBD after test	R02	Reassess	Leaver disablement test completed	Use actual disablement evidence and update residual likelihood
TBD after review	R01 Excessive RBAC privileges	Reassess	Access review / role validation completed	Update score using actual exceptions/remediation

7. Establish Continuous Monitoring and Automated Indicators

What:	Continuously checking risk, control, access, incident, remediation, and environmental-change information after implementation.
How:	Using security alerts, access-review results, control-test outcomes, overdue-remediation thresholds, account/role changes, and dashboard metrics as indicators, with automated or threshold-based alerts where feasible.
Why:	Continuous monitoring is allowing the project to detect when the environment changes or when a control is no longer performing as expected.

Indicator	Starter Threshold / Condition	Program Response
Critical or High risk with overdue treatment	Target date passed	Escalate to GRC Analyst / responsible manager
Repeated failed logins	Example: 5+ failures in a short window	Security review and alert triage
Disabled/expired account activity	Any activity after disable/expiry	Immediate IAM/Security investigation
New privileged role assignment	Any unapproved or unexpected change	Validate approval and review access
Access-review exceptions	Open beyond remediation target	Escalate and update remediation tracker
Control-test failure	Any failed critical control test	Open exception, corrective action, and reassess related risk
Environmental change	New application, role, integration, or major configuration change	Reassess affected assets, controls, and risks

8. Define the Ongoing Review Cycle

What:	Defining how the risk-management program is being reviewed after the initial implementation.
How:	Using recurring risk-register reviews, control tests, access reviews, monitoring reviews, remediation checks, and management reporting so the program remains current.
Why:	A risk-management implementation is only complete when it includes an ongoing review process that is connected to new evidence and environmental changes.

Review Activity	Frequency	Primary Output
Risk register review	Monthly and after major change	Updated risk score, owner, status, treatment, evidence

Review Activity	Frequency	Primary Output
Control test review	After implementation and periodically	Pass/fail result, exception, remediation action
Access review	Quarterly simulation / planned cycle	Access exceptions and corrective actions
Monitoring / detection review	Weekly during monitoring period	Alert quality, tuning, incident evidence
Remediation review	Weekly or biweekly until closure	Updated target/status and escalation if overdue
Management review	Monthly / final project review	Risk posture, key metrics, accepted residual risks

9. Criterion 6 Result

For Criterion 6, Care Access Navigator is implementing risk management as an ongoing program rather than a one-time assessment. The program includes phased deployment, assigned resources, framework customization, gap analysis, integrated IAM/GRC/monitoring procedures, a historically tracked risk register, continuous indicators and threshold alerts, and a recurring review cycle.

Important note: Dates, thresholds, and status values are starter project values. They should be updated as actual controls, tests, remediation actions, and monitoring results are completed.